

Anexo — Informe de hallazgos Cuidarte+ (EV1)

Fecha: 7–8 sep 2026 · Ejecutor: Nicolás Barra · Ambiente: Docker local FE:3333 / API:4444

ZAP baseline sin autenticación solo vio headers. Los defectos graves aparecen con revisión de código, API autenticada y JMeter.

Tabla de hallazgos

ID	Severidad	Hallazgo	ERS
HALL-01	Alta	UI “Ver Documento” no visualiza adjunto (cargador/UX rota); API download 200 OK	RF-4 / NFR-USAB-2
HALL-02	Crítica	Contraseñas en texto plano (sin bcrypt); login medico/medico OK	NFR-SEG-2
HALL-03	Alta	JWT_SECRET por defecto “inseguro”	NFR-SEG-9
HALL-04	Alta	delayMiddleware 5s: JMeter p95 GET examenes/pacientes ~5008 ms (0% <300 ms)	NFR-PERF-1
HALL-05	Media	ZAP: CSP, clickjacking, X-Content-Type-Options, X-Powered-By, CORS	NFR-SEG-5

JMeter (CP-05)

220 samples · 0% error · Login p95 ~14 ms (cumple) · GET Examenes/Pacientes p95 ~5010 ms (no cumple NFR-PERF-1 con delay activo). TG-B 50 VUs sin errores.

Detalle: Informe_Hallazgos_CuidartePlus.md · Anexos/jmeter/ · Anexos ZAP PDF.